

Relatório de Cibersegurança: Simulação de Ransomware

Análise de Malware, Criptografia Assimétrica/Simétrica e Mitigação em Ambiente Controlado

Plataforma DIO
Autor: Adryel Batista de Sena

1. Visão Geral do Projeto

Este documento apresenta um estudo prático focado na mecânica de funcionamento de artefatos maliciosos (Ransomware). Foram analisados os quatro vetores primários de malware e implementada uma prova de conceito (PoC) utilizando a linguagem Python e a biblioteca de criptografia `cryptography.fernet` para demonstrar os processos operacionais de cifragem, solicitação de resgate e restauração de dados.

2. Panorama de Ameaças: Vetores Principais de Malware

Na primeira etapa do estudo, identificaram-se as quatro categorias fundamentais de software malicioso que frequentemente antecedem ou auxiliam infecções por Ransomware:



Figura 1: Mapeamento dos vetores de malware analisados durante o estudo de cibersegurança.

1. Vírus

INFECTOR

Necessita da execução de um arquivo hospedeiro para se multiplicar. Altera outros programas e espalha código malicioso ao ser executado pelo usuário.

2. Worm

AUTÔNOMO

Propaga-se autonomamente por redes explorando vulnerabilidades de serviços sem intervenção humana, causando consumo massivo de banda e infecção em cadeia.

3. Spyware

ESPIONAGEM

Atua silenciosamente coletando dados sensíveis, credenciais digitadas (keylogging) e hábitos de navegação, enviando-os para servidores de comando e controle (C2).

4. Trojan (Cavalo de Tróia)

DISFARÇADO

Disfarça-se de software legítimo para induzir o usuário à instalação. Cria portas de entrada (backdoors) por onde o Ransomware é posteriormente descarregado.

3. Análise do Código de Criptografia (Ransomware.py)

O script de ataque foi desenvolvido em Python para simular a cifragem de arquivos sem permissão. Abaixo, o código ampliado e recortado para leitura detalhada das funções:



Figura 2: Detalhes das funções do ransomware.py (geração de chave, busca de alvos e criptografia Fernet).

Passo a Passo de Funcionamento do Script:

- 1. Geração da Chave** (gerar_chave): Cria uma chave Fernet simétrica de 128-bit e grava no arquivo chave.key.
- 2. Mapeamento** (encontrar_arquivos): Executa varredura com os.walk no diretório test_files, ignorando o próprio script.
- 3. Cifragem** (criptografar_arquivo): Lê o conteúdo original em binário e aplica f.encrypt(), sobrescrevendo o arquivo.
- 4. Nota de Resgate** (criar_mensagem_resgate): Gera o arquivo MENSAGEM_DE_RESGATE.txt contendo a instrução de extorsão.

4. Impacto nos Dados: Antes vs. Depois da Cifragem

Comparativo direto entre o arquivo original e os artefatos gerados pós-execução do malware:

Antes (Texto Claro) Arquivo: senhas.txt Senha visível: DIO!HACK!@#123	Depois (Cifrado) Arquivo: senhas.txt (Modificado) Transformado em hash Fernet Base64.
Chave Gerada ('chave.key') 	Mensagem de Extorsão (Resgate) MENSAGEM_DE_RESGATE.txt Seus arquivos foram criptografados! Para recuperá-los, envie 1 Bitcoin para o endereço XYZ e entre em contato com o suporte.

5. Análise do Código de Descriptografia (Descriptografar.py)

O script de reversão restaura os arquivos afetados utilizando a chave simétrica salva:

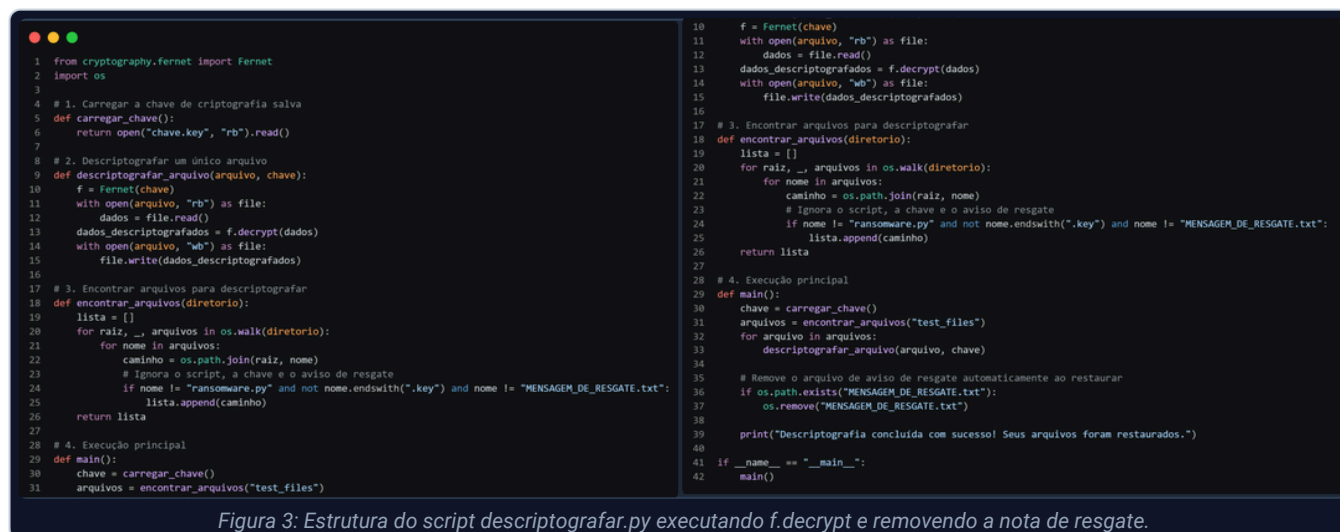


Figura 3: Estrutura do script descriptografar.py executando `f.decrypt` e removendo a nota de resgate.

Confirmação de Sucesso na Terminal:

```
Descriptografia concluída com sucesso! Seus arquivos foram restaurados.
```

Figura 4: Mensagem do sistema confirmando a restauração e remoção do arquivo de resgate.

6. Medidas de Mitigação e Segurança Corporativa

1. Estratégia Backup 3-2-1

Manter 3 cópias dos dados, em 2 mídias distintas, com 1 cópia offsite (offline ou imutável) para garantir recuperação rápida sem pagamento de resgate.

2. Arquitetura Zero Trust & EDR

Implantação de soluções Endpoint Detection and Response (EDR) capazes de identificar comportamentos anômalos de leitura e escrita em massa.

3. Menor Privilégio (PoLP)

Restringir permissões de escrita em diretórios críticos. Usuários padrão não devem possuir privilégios para executar scripts não homologados.

4. Conscientização de Usuários

Capacitar colaboradores contra ataques de engenharia social e Phishing, impedindo o download de Trojans e executáveis maliciosos.

Conclusão Profissional: A simulação reforça a importância vital do entendimento do comportamento interno dos malwares para o desenvolvimento de defesas eficientes. O domínio de linguagens como Python e o entendimento prático de primitivas criptográficas qualificam o profissional de segurança a atuar ativamente na análise de ameaças e resposta a incidentes.